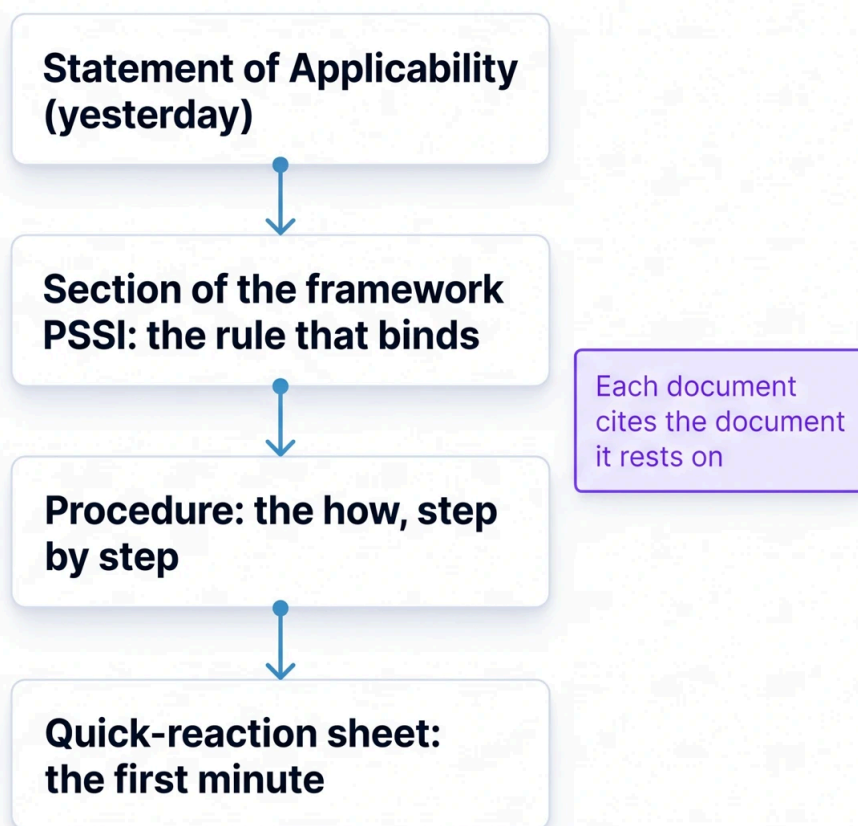


Workshop in the tool: PSSI, quick-reaction sheet, indicators and dashboard

The morning showed where each document lives and who validates it. Before lunch, the group writes, and it writes in the tool: the three documents are born in CISO Assistant's document management, where they then live, versioned, validated by someone other than their author, and linked to the controls they equip. It is an exercise security courses often dodge, because it is less spectacular than a penetration test, and yet it is the one that fills a considerable share of the RSSI's job: a group's security runs on texts, and a badly written text produces exactly the damage of an absent rule, with the added bonus of the illusion of being covered. Three pieces come out of this workshop in class, one hour before lunch: a section of the framework PSSI, a quick-reaction sheet, then the indicator set and the committee dashboard, entered in the tool; the procedure is written during supervised project time by groups that go all the way down the pyramid. All three on the same thread, to show a requirement descending from executive management's commitment down to the first-minute act.

✓ Writing documents that bind



Session objectives

By the end of this lab:

- A **framework PSSI section** for the MERIDIAN group is drafted: vulnerability management, with its codified rules, grounded in the session 8 Statement of Applicability
- A security procedure can be drafted during supervised project time, optional: the quarterly review of privileged accounts, with its roles, its steps and its evidence
- A **quick-reaction sheet** is drafted: the suspected ransomware case at a site of the subsidiary under review
- A verifiable documentary writing discipline is applied, the one that distinguishes a rule from a wish
- The group's **indicator set**, five to eight, and the executive committee's **dashboard** are created in the tool, with at least one reading of the day

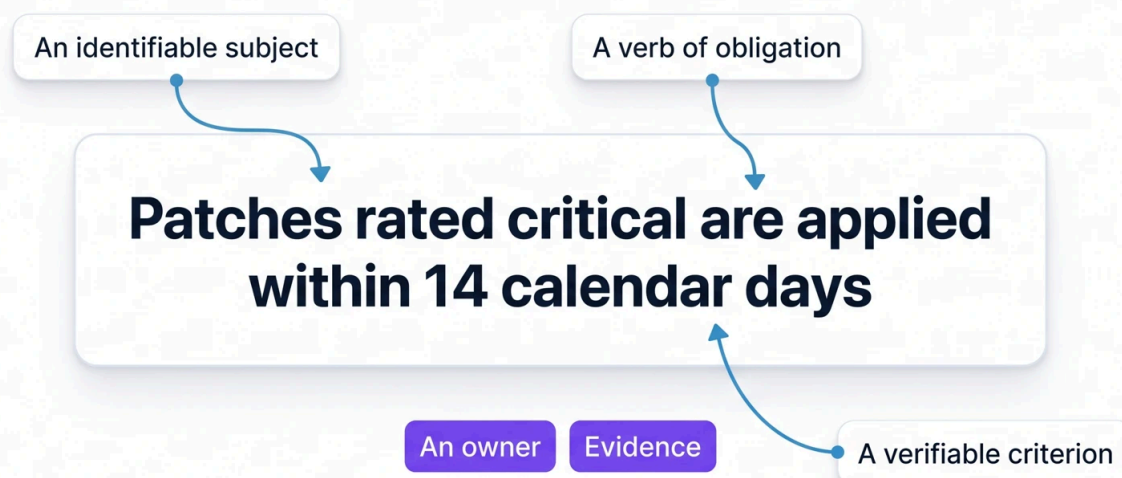
Prerequisites

- The Statement of Applicability from session 8 (deliverable D8), open in the working group's CISO Assistant instance: it is the source for exercise 1, nothing gets written that is not grounded in it.
- The committee page composed at the CISO briefing and the circuits wired at the end of the lecture: the indicators of exercise 4 come out of them.
- The document management of the same instance, Governance menu then Documents: this is where the three documents are written, validated and published, one type per document, Policy, Procedure, and Other for the quick-reaction sheet.
- The morning's lecture: the PSSI's standard outline, the documentation pyramid, the rule that every document cites the floor that grounds it.
- The group's codified directives set since session 1, notably the quarterly review of privileged accounts (ACC-02), the notification of major incidents to the Group CISO within 2 hours (INC-01), and the handling of critical patches within 14 days (COR-01).
- The end of the lecture: the indicator circuit, because every document written here will feed a figure this afternoon.

The writing discipline, before the first line

Five rules of documentary writing, which hold for the three exercises and for an entire career. They come down to one idea: a security document is written to be enforced, audited and executed, never to be admired.

First rule: **a rule is a verifiable obligation**. It has an identifiable subject, a verb of obligation and a verification criterion. "Passwords must be strong" is not a rule, it is a mood; nobody can say who is in breach. Second rule: **every rule has an owner and a proof**. If it is impossible to say who answers for the rule and which record demonstrates its application, what is being written is a hope. Third rule: **ban soft verbs**. "Ensure that", "strive to", "as far as possible" are the three marks of a text afraid to bind; an auditor reads them as escape clauses, and so does a lawyer. Fourth rule: **one sentence, one rule**. Sentences that pile up three obligations and an exception produce debates of interpretation; splitting them is a courtesy to the person who executes. Fifth rule: **every document cites its grounds**. The PSSI section cites the risk or the selected control that justifies it, the procedure cites the rule it rolls out, the quick-reaction sheet cites the procedure it condenses. A document that cannot name its upper floor is an orphan, and the morning said what to think of those.



The official PSSI development guide adds a warning that completes these five rules: it recommends avoiding the copying of security principles without in-depth analysis. A catalog of principles, its own covers sixteen domains, is a starting point; the added value is the adjustment to the context, and at MERIDIAN the context has a name: the risk register and the audit findings the file has been carrying, deliberately, since session 4.

Before (the text that is afraid)	After (the text that binds)
Teams take care to apply security patches as promptly as possible	Patches qualified as critical are applied within 14 calendar days; any overrun is covered by an exemption validated by the Group CISO within 48 hours
Particular attention is paid to accounts holding privileges	Access privileges on the business databases are reviewed every quarter; the signed statement of the review is filed in the subsidiary's records
In the event of an incident, teams strive to alert the security function quickly	Every major incident is notified to the Group CISO within 2 hours; the timestamp of the notification is kept

What is special about the right-hand column: it contains almost nothing but rules the group already owns. The workshop does not invent obligations, it teaches how to write the ones the group's governance has set since session 1.

Exercise 1: the “vulnerability management” section of the framework PSSI (20 minutes)

The workshop's thread starts at the top. In session 8, the Statement of Applicability selected the technical vulnerability management control from Annex A, justified by a risk from the register; the session 4 audit report had observed systems behind on patches; and the rule of critical patches within 14 days (COR-01) exists in the group framework. The framework policy directives as codified in session 1 (ACC-01 to COR-01) are authoritative for this exercise, whatever wording the group adopted. Everything is there. What is missing is the text that assembles these pieces into a defensible policy section.

To produce: the “vulnerability management” section of the MERIDIAN framework PSSI, on this template, one page at most, entered in the tool as a document of type Policy.

Item	Expected content
Purpose and grounds	What the section covers, and what grounds it: the risk from the register, the control selected in the Statement of Applicability, the audit finding it comes to close
Rules	Four to six codified rules, numbered in the group's codification, each verifiable
Responsibilities	Who answers for what, by role, aligned with the session 1 RACI matrix
Exemptions	The exception circuit, with its authority and its deadline
Application and proof	The indicator that will measure the section, and the record that serves as proof

1. **Look up** in the working group's instance, before writing, the status and the justification the Statement of Applicability carries for the technical vulnerability management control: the “purpose and grounds” item must quote that justification, not paraphrase it from memory.
2. **Create** the document in the tool: Governance menu, Documents, New document; reference PSSI-VUL, the section's name, type Policy, the group's domain, content source Authored; under Relations, link the applied control that carries vulnerability handling, or the audit's corrective action that comes closest.
3. **Draft** the rules in the editor, item by item on the template, respecting the five disciplines: among them must appear the correction deadline for critical patches and the exemption circuit, which the group already owns, plus the rules the analysis adds, the inventory of covered systems and the qualification of vulnerabilities for example.
4. **Check** the section against the auditor's test, then save: for each rule, can a third party determine, without questioning the author, who is in breach and on what evidence?
5. **Publish**: submit the revision for review to another group member, who validates it; the tool forbids an author from validating their own text, and that is the lecture's rule, a document without validation binds nobody. The published version 1 is exported as a PDF for the submission file.

Exercise 2, optional during supervised project time: the procedure for the quarterly review of privileged accounts (20 minutes)

One floor down. The directive has existed since session 1 (ACC-02): quarterly review of access privileges on the business databases. This morning's lecture showed that its circuit rested on a procedure never yet written. This exercise is done during supervised project time, after D9; it is not required for the file, but it completes the documentary chain.

To produce: the complete procedure, in the tool as a document of type Procedure, two pages at most, linked under Relations to the treatment plan controls it equips, named accounts and the joiner and leaver procedure for example.

Item	Expected content
Purpose and parent document	What the procedure does, and the framework PSSI rule it rolls out
Scope	The systems and populations covered, with no ambiguity on edge cases; the scope names the edge cases of the subsidiary under review, as the map of power (S3 of the subsidiary pack) and the findings (S5) bring them out
Trigger	What starts the execution: the quarterly deadline, and what happens if it is missed
Roles	Who prepares, who executes, who controls, who signs, by role
Steps	The numbered sequence of operations, each step with its input and its output
Evidence produced	The records created, their format, where they are filed, who can demand them
Indicator fed	The figure this procedure feeds, and how it is calculated from the evidence

1. **Create** the document: Governance, Documents, New document, type Procedure, reference PRO-PRIV, the group's domain, and under Relations the treatment plan controls the procedure equips.
2. **Draft** the procedure by putting oneself in the place of the person who will execute it next quarter without ever having met the writer: that is the test of any operating procedure.
3. **Handle** explicitly the case that hurts, the one soft procedures dodge: a privileged account that nobody can say what it is for. The procedure must say what is done with it, within what deadline, and who decides.
4. **Close** the chain of evidence: show, item by item, how the signed statement produced at the final step makes it possible to calculate the indicator on the last line, with no missing information.
5. **Publish** after validation by another group member, as for the section.

Exercise 3: the “suspected ransomware” ✓ quick-reaction sheet, a site of the subsidiary under review (15 minutes)

Last floor, the shortest and the hardest to write. The quick-reaction sheet is an object this module defines as follows: a single page, fit for posting on a wall, that tells a person under stress what to do in the first minutes of a serious event, before the specialists arrive. It is neither a policy nor a procedure: it is the emergency digest of a procedure, written to be executed by someone who has never read it in calm conditions, at night, on a public holiday.

The context makes the exercise concrete, whatever the sector. The CHU de Rouen is one of the three organizations, with Groupe M6 and Fleury Michon, struck by ransomware in 2019 whose testimonies fed the official guide devoted to these attacks; and the Centre Hospitalier Sud Francilien in Corbeil-Essonnes, attacked on August 21, 2022, saw 11 gigabytes of exfiltrated data published the following month. A site discovering encryption in progress has no time to open the PSSI: it has time to read one page.

To produce: the “suspected ransomware” quick-reaction sheet for a site of the subsidiary under review, that is, the one whose pack the group holds (care facility, warehouse, cluster headquarters or local office), chosen from the map of power (§3) and what crosses the boundary (§6) of the subsidiary pack; one page, structured in three blocks: the immediate actions, the alerts to raise, the prohibitions. In the tool, the sheet is a document of type Other, since no quick-reaction sheet type exists, linked under Relations to the backup or incident response control of the treatment plan.

1. **Create** the document: Governance, Documents, New document, type Other, reference FR-RANCON, the group's domain; the three blocks are written in the editor, one numbered list per block.
2. **Draft** the immediate actions by exploiting what the group's governance already allows: the subsidiary RSSI's emergency isolation right over inter-subsidary flows in the event of confirmed compromise has been in place since session 1, the sheet must say who triggers it, under the title the subsidiary pack gives them, how to reach them, and over which flow (its inter-subsidary dependency from §6 of the subsidiary pack).
3. **Draft** the alerts block with the group's deadlines: the notification of every major incident to the Group CISO within 2 hours is a directive (INC-01), the sheet translates it into a timed action, with the channels in the order in which to try them.
4. **Draft** the prohibitions, because a quick-reaction sheet also protects against reflexes: the well-intentioned acts that destroy evidence or worsen propagation. Each prohibition is written with its reason in a few words, because an unexplained prohibition gets violated under stress.
5. **Test** the sheet in pairs: the neighbor reads it in one minute, watch in hand, then recounts what they would do. What they recount badly, the sheet says badly; fix the sheet, not the neighbor.
6. **Publish** after validation by the partner who ran the test, then export the PDF: a quick-reaction sheet lives printed next to the workstation, not only in the tool.



Exercise 4: the indicators and the dashboard in the tool (25 minutes)

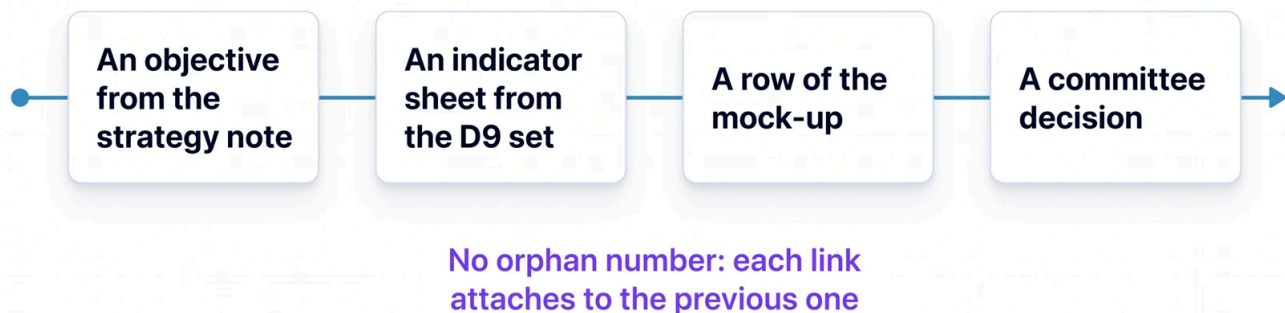
The D9 template

Deliverable D9 is a set of five to eight indicators, each defined by a sheet. Below five, the set does not cover the three kinds executive management must see; above eight, the sixty-line table sorted this morning is being recreated. The sheet, for its part, is non-negotiable: an empty item is a rejected indicator.

In the tool, the metric definition carries what is stable, the name, the kind, the unit, the target and the direction of improvement; the metric instance carries what belongs to the group, the formula, the source, the threshold, the frequency, the recipient, the objective watched and the dated readings.

Item	Requirement	Where it lives in the tool
Name and kind	A jargon-free name, and its kind: compliance, risk or operations	Metric definition: reference, name, and the kind at the head of the description
Definition	What the indicator measures, in one sentence a committee member understands unaided	Metric definition: description
Formula	The exact calculation: numerator, denominator, unit, inclusion and exclusion rules	Metric instance: first line of the description
Data source	Where the values come from: tool, register, procedure statement, with the owner of the reading	Metric instance: description, and the owner in the Assigned to field
Threshold	The target, the alert threshold, and what a crossing triggers	Definition: default target and the "higher is better" box; instance: target value, alert threshold in the description
Frequency	The reading rhythm and the presentation rhythm, if they differ	Metric instance: collection frequency
Recipient	Who receives it, and the decision it informs for that recipient	Metric instance: description, with the strategy note objective watched
Value of the day	The value at the lab's date, with the count that justifies it	Metric instance: one dated sample, its value, its observation

Two composition rules complete the template, and they are the deliverable's acceptance criteria: the set mixes the three kinds, compliance, risk and operations; and each indicator is explicitly linked to an objective of the strategy note, because an indicator that watches no group objective is an orphan figure, however well built. Finally, at least one indicator in the set must be calculable this very day, with the data in the MERIDIAN file: it is the proof that the set is not a wish for future tooling.



Composing the set (5 minutes)

The work does not start from a blank page, and that is a pedagogical choice: an RSSI taking up a post always inherits existing indicators. The material: the executive dashboard KRIs and the directive KPIs set since session 1; the indicators promised by the documents of the writing workshop; the hole in the net identified at the end of the lecture, the progress of segmentation at Logistique, which no figure was watching; and the reserves of deliverables D7 and D8, where risk indicators the group has not yet formalized can be calculated.

1. **Select** five to eight indicators from this material, checking coverage of the three kinds and noting, for each one, the strategy note objective it watches, its unit, count or percentage, and its direction of improvement.
2. **Arbitrate** the duplicates: when two candidate indicators inform the same decision, keep the one whose data source is the more reliable; noting the other as dropped is not required, but the session 10 panel appreciates documented choices.
3. **Mark** with a distinctive sign the indicators that are calculable on the spot with the file or with the instance: they will be read in step 2, and they are the ones that will prove the set stands up.

Creating the indicators (12 minutes)

To produce: one complete sheet per indicator, in the tool, as one metric definition and one metric instance per line of the set. The trap of this step is not laziness, it is false precision: a formula that looks exact but for which nobody can say where the denominator lives.

1. **Define** each metric: Metrics, Metric definitions, Add; reference IND-01 and following, a name without jargon, a description that starts with the kind, KPI or KRI, and says what the figure measures, the group's domain, category Quantitative, unit Count or Percentage, default target, provider in the group's name, and the "higher is better" box unticked for any count that should go down.
2. **Instantiate** each indicator: Metrics, Metric instances, Add; same reference, the chosen definition, the group's domain, then in the description the formula and the source, the two items that kill, the alert threshold and what its crossing triggers, the recipient and the decision it informs, the strategy note objective watched; collection frequency, target value, and the owner of the reading in Assigned to. Status Active for indicators that can be read today, Draft for those whose source is still to be opened.
3. **Read** the day's value of the indicators marked in step 1: open the instance, Add a sample, today's timestamp, the value, and in the observation the count that justifies it, numerator and denominator, with the document it comes from. The session 7 risk register makes it possible, for example, to count on the spot the scenarios left without a treatment decision, and the session 8 audit the non-compliant requirements. The subsidiary pack provides another, specific to the subsidiary under review, that is, the one whose pack the group holds, calculable on the spot from its pieces: Santé, the accounts of leavers never deactivated set against the active accounts, 214 out of 3,940 (\$5); Logistique, the backup restorations tested since the WMS went live, zero (\$5); Éducation, the subscriptions taken out outside the IT department with no contract, eleven out of eleven (\$4 and \$5); Territoires, the contractual requirements followed by a control, zero out of about thirty delegation contracts (\$4 and \$5).

The committee dashboard (8 minutes)

D9 ends with the dashboard: the page the Executive Committee will see every quarter, built in the tool, Metrics menu, Dashboards. It is not a graphic design exercise, it is a hierarchy exercise: the grid has twelve columns, each tile has a position and a size, and the page must say the essential in thirty seconds of reading.

Period covered

Indicator

Value

Target

Threshold

Trend

Messages and requested decisions

1. **Create** the dashboard: Metrics, Dashboards, Add; reference, name, the group's domain, and in the description the period covered and the reading rule.
2. **Compose** the page through Edit layout: one KPI card per indicator, through Add custom metric, showing the latest value and the target; one or two builtin views, through Add builtin metric, drawn from the audit, result breakdown, or from the register, treatment option breakdown; a text tile at the top for the period, a text tile at the bottom for the messages and decisions requested, the one this morning's report would fill.
3. **Order** the tiles by decision importance, not by technical family, by dragging them, then save: the committee reads from top to bottom and stops when interrupted.
4. **Check** the coherence end to end: each tile matches an indicator, each indicator a definition and a strategy note objective, and no figure on the page comes out of nowhere; a dated screenshot of the page joins the submission file, it is the D9 mock-up.

Answer keys and assessment criteria